

Active Directory (AD)

מודול 13 — האקינג אתי מהיסוד

מבנה AD-Kerberos ◀

BloodHound-1 Enumeration ◀

LLMNR, Kerberoasting, AS-REP ◀

Pass-the-Hash → Domain Admin ◀

דרישת מעבדה ⚠

12GB+ RAM = AD דורש DC + לקוחות ◀

אין מספיק?  תרגל בענן ◀

TryHackMe: Attacker Directory, Attacking Kerberos ◀

זו הדרך המומלצת למודול הזה ◀

למה AD הכי חשוב?

- ◀ ~95% מ-Fortune 500 משתמשות ב-AD
- ◀ כל בדיקה פנימית = תקיפת AD
- ◀ DC = שליטה בכל הארגון
- ◀ היעד: משתמש רגיל → **Domain Admin**

מושגי יסוד

◀ **Domain / DC** — גבול לוגי + השרת המנהל

◀ **Kerberos** — אימות מבוסס כרטיסים

◀ **NTLM** — אימות ישן (hashes)

◀ **SPN** — מזהה שירות (מפתח ל-Kerberoast)

זרימת Kerberos

- ◀ משתמש → מבקש **TGT** מה-DC
- ◀ עם TGT → מבקש **TGS** לשירות
- ◀ מציג TGS לשירות → גישה
- ◀ התקיפות מנצלות **תכנון**, לא באגים

Enumeration

◀ `crackmapexec smb <dc>` — דומיין, גרסה

◀ `enum4linux-ng -A` — משתמשים, shares

◀ גם משתמש מוגבל מתשאל את **כל** AD

◀ משם בונים נתיב תקיפה

LLMNR / NBT-NS Poisoning

- ◀ נקודת כניסה — לרוב **ללא אישורים**
- ◀ מחשב "צועק" שם שגוי → Responder עונה
- ◀ **NTLMv2 hash** → hashcat -m 5600 לוכד
- ◀ מ"אין כלום" לאישורים ראשונים

Kerberoasting

◀ כל משתמש דומיין מבקש TGS של שירותים

◀ `GetUserSPNs.py -request`

◀ פיצוח `offline: hashcat -m 13100`

◀ חשבונות שירות = סיסמאות ישנות/חלשות

AS-REP Roasting

חשבונות ללא Kerberos preauth ◀

`GetNPUsers.py -no-pass` ◀

פיצוח: hashcat -m 18200 ◀

◀ **לא צריך אישורים** — רק שמות

Pass-the-Hash / Ticket

משתמשים ב-NTLM hash **כמו שהוא** ◀

```
crackmapexec smb -u admin -H <hash>
```

 ◀

```
psexec.py -hashes , evil-winrm
```

 ◀

לב התנועה הרוחבית ב-AD ◀

BloodHound

- ◀ אוסף יחסי AD → מצייר גרף
- ◀ "Shortest Path to Domain Admins"
- ◀ הופך ניחוש למדע
- ◀ כלי חובה בכל בדיקת AD

DCSync-1 Domain Admin

DCSync — שכפול מסד הסיסמאות מה-DC ◀

שולף hash של Administrator / krbtgt ◀

TGT — **Golden Ticket** מזויף, גישה נצחית ◀

🏆 "Domain Admin = "Game Over" ◀

סיכום מודול 13

◀ AD = היעד של בדיקה פנימית

◀ LLMNR → Kerberoast → BloodHound → PtH

◀ DCSync → Domain Admin

◀ ההגנה = שכבות (LLMNR, gMSA, least-priv כבה)

◀ **תרגול** → `practice.md` · **פתרונות** → `solutions.md`